

Security Frameworks: NIST CSF, ISO 27001 & CIS

Why Frameworks Exist

Frameworks give a shared vocabulary and a yardstick. "Our security is good" means nothing; "we align 15 of 20 NIST CSF subcategories and audit against it" means something.

NIST Cybersecurity Framework (CSF) – the operating system of US security

Six functions (CSF 2.0):

- Govern - the rules, context, roles
- Identify - what do we have and what matters
- Protect - boxes to keep bad stuff out
- Detect - how we know something's wrong
- Respond - what we do when it happens
- Recover - how we get back up

Each function → categories (e.g. PR.AT = awareness & training) → subcategories (PR.AT-1: "All users are informed and trained..."). Tiers (Partial → Risk-Informed → Repeatable → Adaptive) say how *mature* you are.

Why you'll meet it: it's the de-facto language of US cybersecurity, cyber insurance, and vendor risk.

ISO/IEC 27001 – the certifiable one

An international **management system** (ISMS) – policies, risk, continual improvement

Annex A = 93 (approx) controls you tailor to your context

Certifiable – an auditor checks you; certs renew every 3 years; the audit culture

Not security-brilliance: it's *governance discipline* – evidence, records, ownership

CIS Controls – the operational, actionable list

18 controls, prioritized:

- 01 Inventory of enterprise assets
- 02 Inventory of software assets
- 03 Data protection
- 04 Secure config of assets and software
- 05 Account management
- 06 Access control / MFA
- 07 Continuous vuln management
- 08 Audit log management
- 09 Email & browser protections
- 10 Malware defenses
- 11 Data recovery
- 12 Network infrastructure management
- 13 Network monitoring / defense
- 14 Security awareness
- 15 Service provider management
- 16 Application software security
- 17 Incident response
- 18 Penetration testing

Why organizations love them: "Do these 18 things in this order." The IG1/2/3 implementation groups say what to do first.

Choosing a Framework

Question	They answer
"Which do I START with for culture?"	CIS Controls / NIST CSF
"Do I need an audited certificate?"	ISO 27001
"Are we a vendor/ SaaS?"	SOC 2 (module 2 of this track)
"Am I Asia/EU cloud?"	ISO 27001 / TISAX / HITRUST (industry)

The insight: frameworks don't *be* security – they make it *structured, measurable, and auditable*. Know the trio: NIST CSF (IT), ISO

(certification), CIS (ops list).

[← Module start](#)

[SOC 2, Audits & Third-Party Ri...](#)